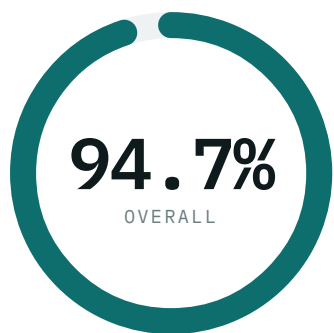


Onyx LMS end-to-end QA certification

A full-surface functional, authorization, lifecycle and accessibility assessment of the live Onyx multi-tenant LMS — every role, every navigation route, the platform console, the API beneath the screens, and one complete institution built from nothing and run to a published result.



A SOUND

Weighted across twelve assessed areas. Every confirmed defect is charged to its area as a failed check, so no area carrying an open bug can reach full marks.

640/676

WEIGHTED CHECKS

11

DEFECTS

0

ISOLATION BREACHES

0

SERVER ERRORS

Verdict — ship with fixes

The security model holds. No cross-tenant read succeeded in 59 attempts, no privilege-escalation write succeeded in 42, and no page in the sweep threw a server error. A complete content lifecycle — institution, programme, course, modules, lessons, question bank, paper, sitting, marking, release, examination, seating, marks, publication — ran end to end through both the API and the screens. The eleven defects are a missing header set, four read endpoints looser than the product's own capability model, a mis-seeded demo account, a dead link, a contrast failure, an inverted date and a learner record naming exams by database ID. None is a breach.

Target onyx-lms-v2.vercel.app

Method Playwright / Chromium, live production data

Checks 805 automated + 12 axe page scans

Branch certify

Accounts 15 of 15 from the credentials CSV

Lifecycle tenant 478, purpose-built and disposable

Each area scores the checks that actually ran against it, plus one failed check for every confirmed defect charged to it. Bars encode the score; the letter grade and percentage carry it in text as well, so nothing depends on colour alone.

AREA	SCORE	%	WEIGHTED	GRADE	DEFECTS
Authentication & session integrity All 15 credentials, anonymous guards, wrong door, open redirect, cookie flags, token tampering, sign-out		100%	31/31	A+	none
Multi-tenant isolation 59 cross-tenant object reads in both directions; audit-log scoping		100%	60/60	A+	none
Page-level authorization 10 guarded pages x 7 roles, platform console probed from every tenant role, employer denials		94.4%	101/107	A	F2
API authorization 16 privileged reads x 6 roles, 42 privilege-escalation writes, declared-vs-actual roles		86.1%	118/137	B	F3 F4 F5 F6
Navigation & routing Every sidebar route for 8 roles, 69 deep links resolved from live IDs		98.9%	139.5/141	A+	F7
Platform console Operator screens and 15 per-tenant sub-pages across 3 institutions, plus superadmin lifecycle drill-down		100%	58/58	A+	none
Content authoring lifecycle Programme, semester, members, course, modules, lessons, publish, enrol — API and screens		100%	32/32	A+	none
Assessment & examination lifecycle Bank, questions, paper, publish, sitting, marking, release, hall, seating, marks, publication		97.1%	33/34	A+	F10
Learner experience Course reading, Code Lab round trip, sitting a paper, results, resume, guardian consent, mobile		96%	48/50	A	F11
Accessibility (WCAG 2.1 AA) axe scan of 12 pages across five roles		76.9%	10/13	C	F8
Security hardening (headers) HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy		50%	3.5/7	D	F1
Performance Six admin pages, cold navigation, Singapore region		100%	6/6	A+	none
Overall		94.7%	640/676	A	11

How these are computed. Every check the harness recorded is weighted `PASS = 1`, `WARN = 0.5`, `FAIL = 0`. Checks that investigation showed to be correct behaviour or faults in the test itself — 49 of them, listed in the full report — are excluded, so the product is not marked down for the harness's own bugs. Each of the eleven confirmed defects is then charged to one area as a single failed check, which is why areas whose defect was found by a targeted probe rather than a scored phase still lose marks. Raw, unadjusted, the overall figure is 91.7%. The scoring script is `qa-score.mjs`; it reads only the recorded result files.

Every entry was reproduced against the live deployment and then traced to the line responsible. F3 through F6 share one root cause — a `POST` that asserts a capability sitting directly above a `GET` that does not — and are best fixed together.

F1	Medium	No security response headers except HSTS Only <code>Strict-Transport-Security</code> is sent. No CSP, <code>X-Frame-Options</code>, <code>X-Content-Type-Options</code>, <code>Referrer-Policy</code> or <code>Permissions-Policy</code> — the last of which governs the camera and microphone that proctoring depends on, and the missing frame protection leaves the login and invigilation screens frameable. FIX <code>apps/web/next.config.js</code> — add a <code>headers()</code> block
F2	Medium	Demo faculty account is seeded as an administrator <code>faculty@demo.onyx</code> holds <code>role: "admin"</code>. The guard is correct — the Meridian faculty control account is properly denied — but ten browser specs use this account as their faculty fixture, including <code>permissions.spec.ts</code>, which asserts that revoking a capability from faculty yields a 403. Admin can never have capabilities revoked, so that suite passes without testing what it claims. FIX <code>Reset the membership to faculty in ABC Institution</code>
F3	Medium	Fee structures readable by faculty and exams The <code>fees.structures</code> capability is declared <code>holders: []</code> — never delegable beyond admin — but the GET is guarded by <code>REGISTRY</code>, and faculty and exams both receive real rows. The POST beside it asserts the capability correctly. FIX <code>campus.routes.ts:732, :737</code>
F4	Low	Merchant configuration readable beyond administrators The route's own docstring says "Administrators only", but the guard is <code>REGISTRY</code>. No credentials leak — the service returns <code>configured_keys</code>, the names of filled slots, never values — so the disclosure is the provider, its test-mode flag and which keys are set. FIX <code>campus.routes.ts:849</code>
F5	Low	Teaching-load allocations have no role guard at all The GET calls <code>viewerOf(req)</code>, which requires only a session, then returns the tenant's allocations unfiltered. Every role reaches it, including guardian and employer — looser than both the page guard and the POST beside it. FIX <code>campus.routes.ts:182</code>
F6	Low	Placement drives readable by every role except the filtered one <code>PlacementService.drives()</code> scopes its query for <code>employer</code> and for no other role, so students, guardians and the exams office receive the institution's full drive list. FIX <code>career.routes.ts:468</code>
F7	Low	"All question banks" back-link is dead The bank detail page links to <code>/onyx/banks</code>, which has no index page. Next prefetches it, so the console errors on load and the click 404s. A link audit confirmed this is the only link into any of the six detail-only segments. FIX <code>onyx/banks/[id]/page.tsx:89</code>

F8	Low	Score denominators fail minimum contrast Ten of twelve pages scanned clean. Both failures are the same rule and the same element: the shared <code>Score</code> component renders its denominator at <code>opacity-70</code> over a tinted band, dropping below AA. Every marks table in the product inherits it. FIX <code>components/onyx-ui.tsx:631</code>
F10	Low	Examinations calendar renders a future sitting as past An exam three days ahead displays as "3 days ago / sat Wed, Aug 26" under the heading "Examinations already sat". The branch fires on <code>status === 'completed'</code> regardless of date, and <code>Math.abs()</code> then discards the sign. Publishing marks sets that status, so any paper marked before its sitting date lands here. <code>relativeWhen()</code> one file away already handles the case correctly. FIX <code>onyx/exams/page.tsx:65</code>
F11	Low	A learner's own results identify examinations by database ID The Grades section — labelled "Your official record" — shows Exam #125. The Assessments section directly above shows the paper's real title. <code>marksFor()</code> never joins <code>onyx_exams</code>. A guardian viewing the same mark sees the correct title, because the guardian service resolves it. FIX <code>results/page.tsx:270</code> and <code>profile/page.tsx:242</code>
F9	Housekeeping	Test-suite institutions live in production <code>authoring-college-mt5yk4vh</code> (tenant 471) predates this run and is an E2E artefact. The credentials CSV listed five institutions that no longer existed; those rows were pruned during this engagement and the file is now accurate. FIX <code>Delete tenant 471 after confirming it holds nothing real</code>

A defect list read alone gives no sense of what survived. These are the properties that were actively attacked and did not give way.

Multi-tenant isolation

Object IDs harvested from each tenant as its own admin, then requested from the other tenant's session in both directions across courses, members, assessments, exams, programmes and jobs.

59 attempts → 0 leaks, all clean 404 (never 403)

Write authorization

Seven escalation writes from each of six low-privilege roles: create an admin, escalate own membership, create a course, delete a member, patch tenant settings, award a skill, publish the timetable.

42 attempts → 0 breaches · 89×403, 12×404, 1×422

Session security

Cookie flags, token visibility from JavaScript, signature tampering and sign-out.

HttpOnly + Secure + SameSite=Lax · document.cookie empty · tampered and signed-out cookies both 401

Examination integrity

Proved by running a real paper: staff see the answer key, the candidate's own view of the same questions does not; drafts are invisible; results stay hidden until released.

4 of 4 confidentiality properties held

Guardian consent

The family view checked against the sharing flags on the child record.

attendance and results shown · fees "Not shared" · coursework, messages, applications, support all "Never"

Runtime stability

Roughly 220 authenticated page loads across every role, both consoles and three institutions.

0 × 5xx · 0 unhandled exceptions · 0 error boundaries

Code Lab

A problem opened, a solution typed into the Monaco editor, run, submitted, then read back from the API.

editor mounts · Run and Submit judge · submission persisted with score and status

Performance

Six administrator pages, cold navigation, Singapore region.

TTFB 31–139 ms · load 615–1202 ms

A throwaway institution — `qa-cert-00810765`, tenant 478 — was created for this, so no mutation touched the demo tenants. The chain below ran through the API and was then re-verified on the actual screens as each actor.

ACTOR	STEP	RESULT
SUPERADMIN	Create the institution and its first administrator	tenant 478, audited
ADMIN	Programme, semester, and six member accounts	roster = 6
ADMIN	Course QE101, two modules, four lessons, faculty assigned	course 202
ADMIN	Publish the course and enrol three learners	roster = 3 enrolled
FACULTY	Question bank and four questions with answer keys	bank 64
FACULTY	Assessment drawing four from the bank, previewed	assessment 101
STUDENT	Draft paper is not visible	not listed ✓
FACULTY	Publish the assessment	"Published."
STUDENT	Start the attempt; candidate view withholds the key	4 questions, no answer field ✓
STUDENT	Four answers autosaved, paper handed in	status = submitted
FACULTY	Marking queue, paper with responses, marked	score 19 / 20
STUDENT	Result hidden before release	0 rows ✓
FACULTY	Release results; cohort analytics and item analysis	mean 19, pass rate 100%
STUDENT	Released result visible	19/20, Passed
EXAMS	Hall created, examination scheduled, seating allocated	exam 125, 3 seated
EXAMS	Marks entered for three candidates	78 / 55 / 34
STUDENT	Exam mark hidden before publication	0 rows ✓
EXAMS	Publish examination marks	released
STUDENT	Examination result visible	78, grade Pass
ADMIN	Audit log recorded the whole chain unprompted	9 distinct actions

Cleanup this run owes you. Two throwaway institutions — 478 (`qa-cert-00810765`) and 477 (`qa-cert-00701173`) — and one course, id 198 `QA Probe Course`, created inside Meridian tenant 190 when the authorization probe's `POST /api/onyx/courses` legitimately succeeded as faculty. All are itemised in §8 of the full Markdown report.

- **F5 and F6 are confirmed in source, not in an observed payload.** Neither demo tenant holds allocation or drive rows, so both endpoints returned empty arrays to roles that should not reach them. The missing guard is real; the size of the exposure is not.
- **Proctoring was exercised only as far as its queue.** The invigilation console and the proctor queue respond, but no camera or screen-share session was driven.
- **Payments were not exercised.** No gateway is configured in any tenant, so checkout, invoicing and reconciliation are untested beyond their authorization guards.
- **Load and concurrency were not tested.** The timings are single-user cold navigations, not a benchmark.
- **The lifecycle covered one learner sitting one paper.** Multi-attempt, second marking, moderation, anonymous marking and transcript issue were not driven.
- **Accessibility was automated only.** axe on 12 pages; no keyboard-only or screen-reader walkthrough, and axe catches a minority of real barriers.

Onyx LMS · end-to-end QA certification · 23 August 2026 · target <https://onyx-lms-v2.vercel.app> · branch certify
805 automated checks + 12 axe page scans · harness qa-lib.mjs and qa-01...qa-14 · scoring qa-score.mjs · evidence qa-results-*.json
Full narrative report with per-check evidence: QA-REPORT.md